

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA5117

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 50

Annexure A

Industry Problem-Solving Task

Code of Conduct:

*I **ch.Bhavya sri/192411249**_(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

I understand that any violation of academic integrity rules will result in disciplinary action.

CH.Bhavya Sri

Signature of the student:

Annexure A
Industry Problem-Solving Task

1. A multinational enterprise is deploying IPSec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
 - B. Design packet flow with appropriate IPSec modes (transport/tunnel)
 - C. Justify protocol selection for different data types
 - D. Evaluate performance vs security trade-offs
-
2. An organization faces frequent key management issues in its IPSec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
 - B. Design an automated key management mechanism (e.g., IKE-based)
 - C. Propose a strategy for key renewal and revocation
 - D. Evaluate scalability and fault tolerance
-
3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
- B. Analyze key management and trust models
- C. Recommend a solution with justification
- D. Design a high-level implementation workflow

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

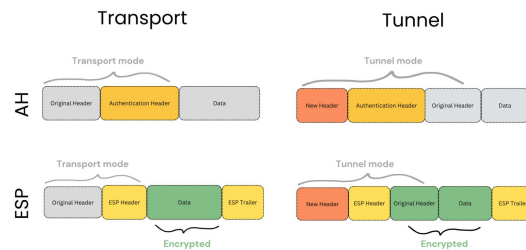
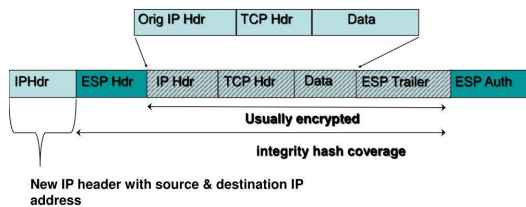
- A. Identify limitations of existing filtering techniques
 - B. Analyze email headers for spoofing indicators
 - C. Design an improved detection model (rule-based or ML-based)
 - D. Evaluate effectiveness and false positive handling
5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

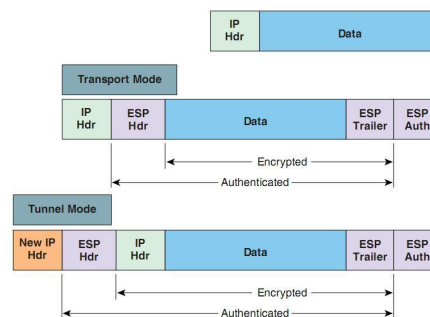
- A. Identify potential certificate-related vulnerabilities
- B. Analyze trust chain and validation process
- C. Propose secure certificate storage and management practices
- D. Recommend improvements for user awareness and system configuration

1. IPSec – AH and ESP

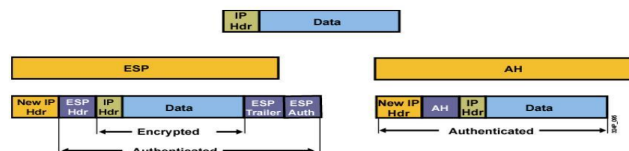
IPSec ESP Tunnel Mode



	AH	ESP	
	AH	ESP encryption	ESP encryption with authentication
Access control	✓	✓	✓
Connectionless integrity	✓		✓
Data origin authentication	✓		✓
Rejection of replayed packets	✓	✓	✓
Confidentiality (encryption)		✓	✓
Limited traffic flow confidentiality		✓	✓



ESP and AH Header



- ESP allows encryption and authenticates the original packet.
- AH authenticates the whole packet (including the header) and does not allow encryption.

Introduction:

IPSec is a network security framework used to protect IP communication over an untrusted network such as the Internet. It mainly uses **Authentication Header (AH)** and **Encapsulating Security Payload (ESP)**.

A. AH, ESP or Both

AH: Provides authentication and integrity. It does not provide encryption.

ESP: Provides confidentiality through encryption and can also provide integrity and authentication.

AH + ESP: Can be combined when both sets of protection are specifically required.

For a multinational company, **ESP is generally the practical choice for sensitive branch-to-branch traffic** because it provides confidentiality as well as integrity/authentication.

B. IPsec Modes

Transport Mode:

IP Header → ESP/AH → TCP/UDP → Data

It is mainly suitable for **host-to-host communication**.

Tunnel Mode:

New IP Header → ESP → Original IP Header → Data

It protects the original IP packet and is commonly used for **VPN gateway-to-gateway communication**.

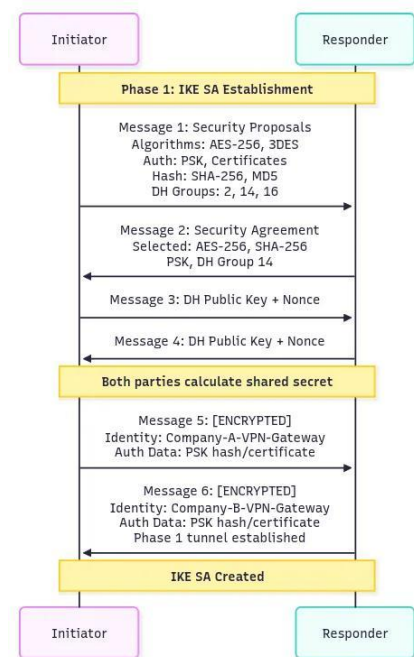
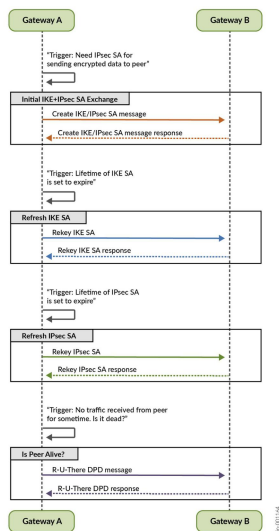
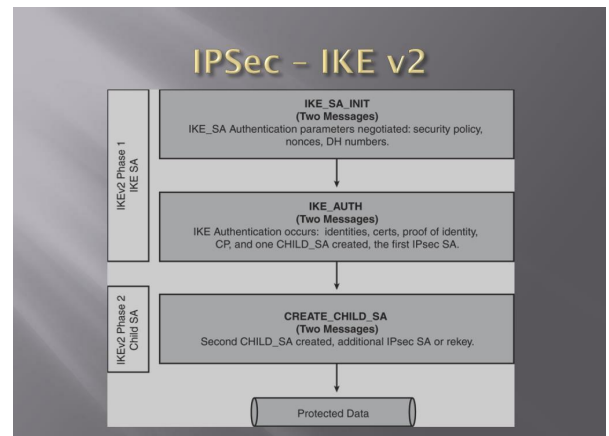
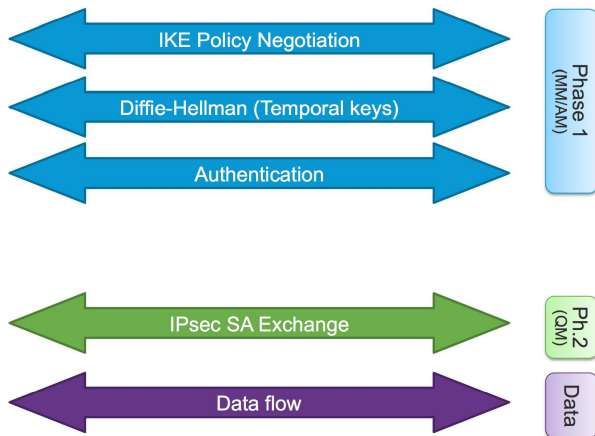
C. Suitable protocol

Traffic	Recommended protection
General non-sensitive traffic	AH, where encryption isn't required
Confidential business information	ESP
Financial/customer information	ESP
Branch-to-branch VPN	ESP Tunnel Mode

D. Performance vs Security

AH has less processing overhead because it does not encrypt the data. ESP requires additional processing for encryption and authentication. Tunnel mode also adds an outer IP header, creating some additional overhead. Therefore, **ESP Tunnel Mode provides strong security at the cost of some additional processing and packet overhead**.

2. Security Associations and Key Management



An **IPsec Security Association (SA)** contains the security parameters needed to protect communication. The organization is facing expired and mismatched keys, so automated key management is required.

A. SA lifecycle problems

Common problems are:

Expired keys

Mismatched keys

Incorrect security parameters

Manual configuration errors

Failure to renew keys

Poor monitoring of SA status

B. IKE-based solution

IKE (Internet Key Exchange) can automate the negotiation of security parameters and keys.

Process:

Device A → IKE Negotiation → Authentication → Key Exchange → SA Creation
→ Secure IPSec Communication

This reduces manual key configuration.

C. Key renewal and revocation

- Give every SA a defined lifetime.
- Automatically renew keys before expiration.
- Revoke compromised keys immediately.
- Remove old SAs after successful renewal.
- Monitor SA status continuously.

D. Scalability

For a large enterprise, centralized policies, automated renewal, monitoring and redundant systems can reduce failures and make the solution scalable.

3. PGP vs S/MIME

S/MIME vs. PGP/MIME (OpenPGP)



S/MIME y PGP/MIME son los dos principales tipos de encriptación de mail.

S/MIME

- * Autoridad centralizada
- * Integrada en empresas basadas en web, como Gmail y Outlook
- * Clave hecha para ti

PGP/MIME

- * Autoridad descentralizada
- * Necesita una encriptación de tercera parte
- * Tienes flexibilidad para crear tu propia clave

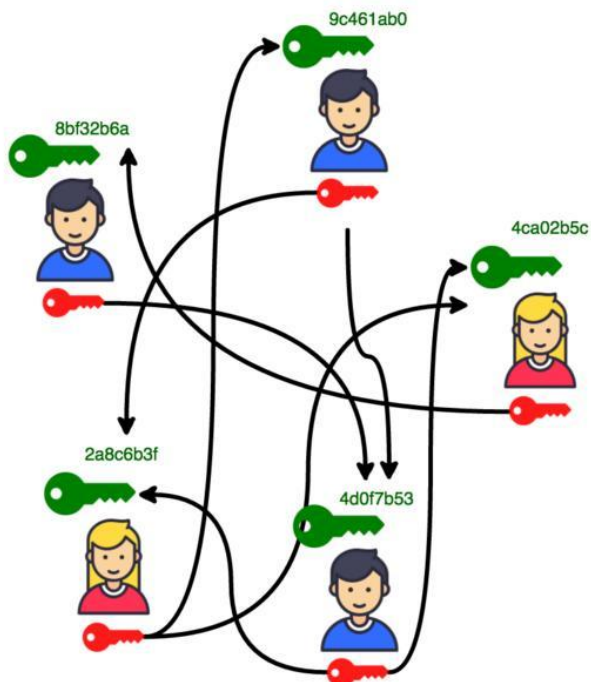
Proveedores de correo que soportan S/MIME:

Gmail, Outlook, & iOS

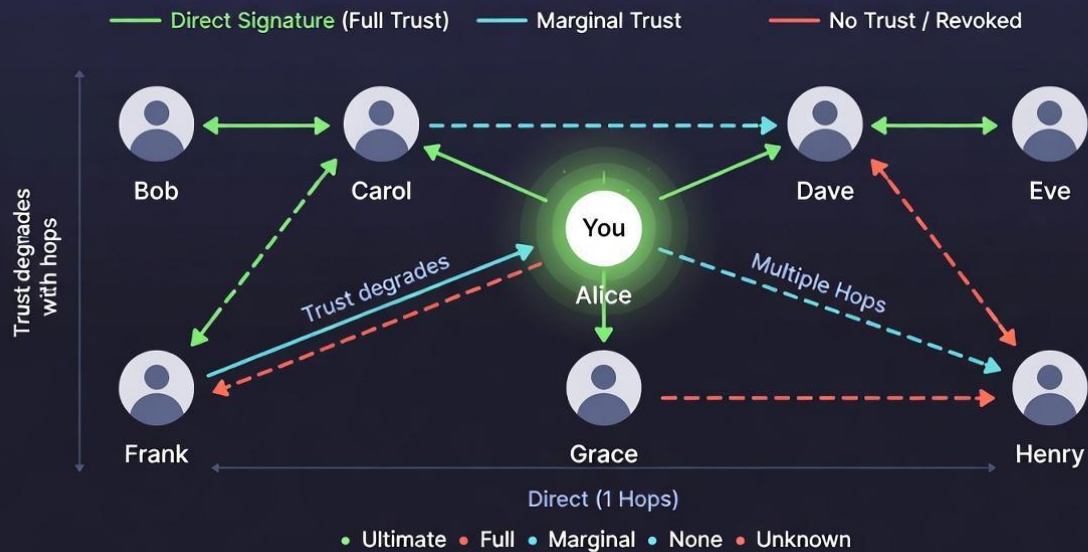
Proveedores de correo que soportan PGP/MIME:

Yahoo, AOL, & dispositivos Android

PGP / WEB OF TRUST



Web of Trust (WoT) Model



The financial company needs secure email for sensitive transactions. The assessment specifically asks for comparison of **PGP** and **S/MIME**.

A. Comparison

Feature	PGP	S/MIME
Trust model	Web of Trust	Certificate Authority (CA)
Key management	More user-controlled	Centrally managed
Enterprise management	More difficult	Easier
Digital signature	Yes	Yes
Encryption	Yes	Yes
Enterprise integration	Moderate	High

B. Trust model

PGP:

Users can verify and trust each other's public keys. It uses a decentralized **Web of Trust** model.

S/MIME:

Uses digital certificates issued through a **Certificate Authority**. This makes centralized enterprise management easier.

C. Recommendation

For a **financial services company**, I would recommend **S/MIME** because centralized certificate management and enterprise integration are important requirements.

D. Implementation workflow

User



Obtain S/MIME Certificate



CA Validation



Install Certificate



Sign / Encrypt Email

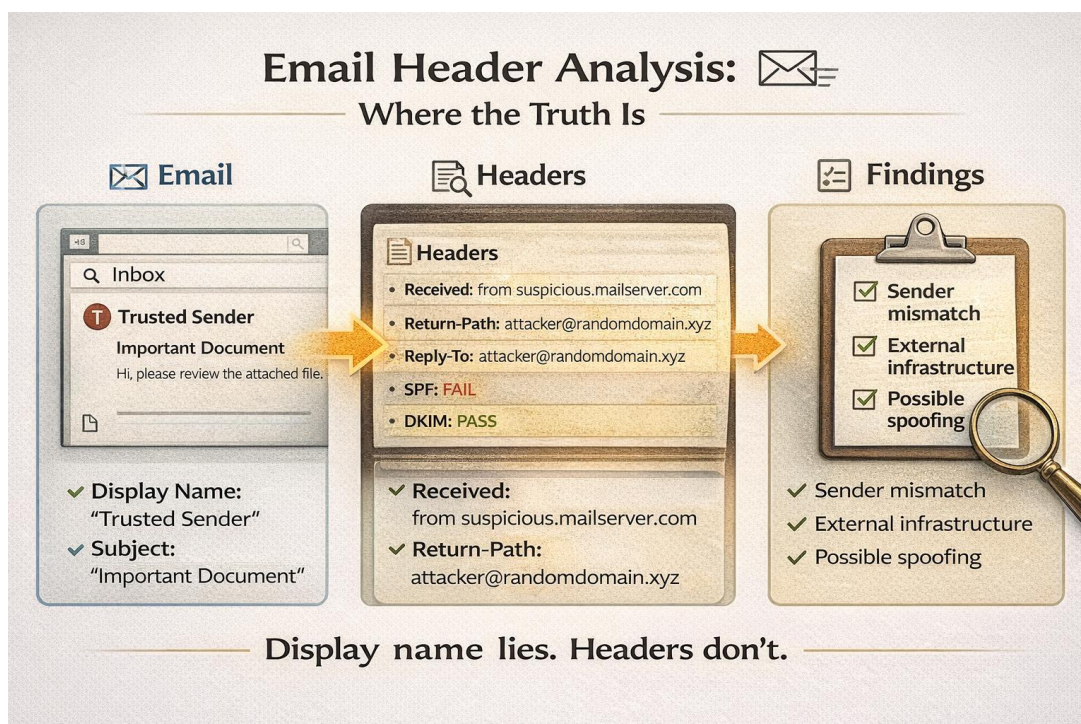


Receiver Validates Certificate

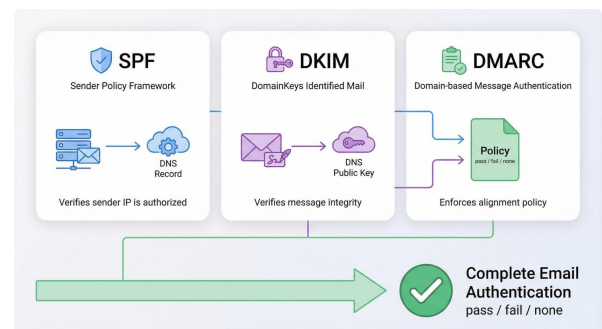
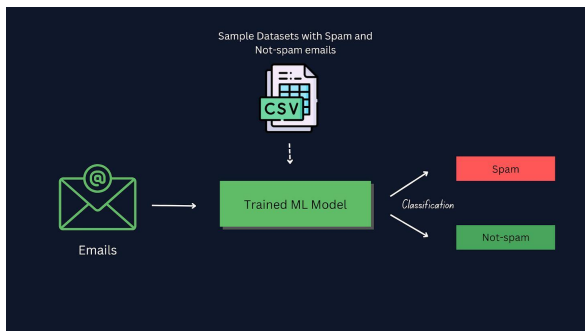
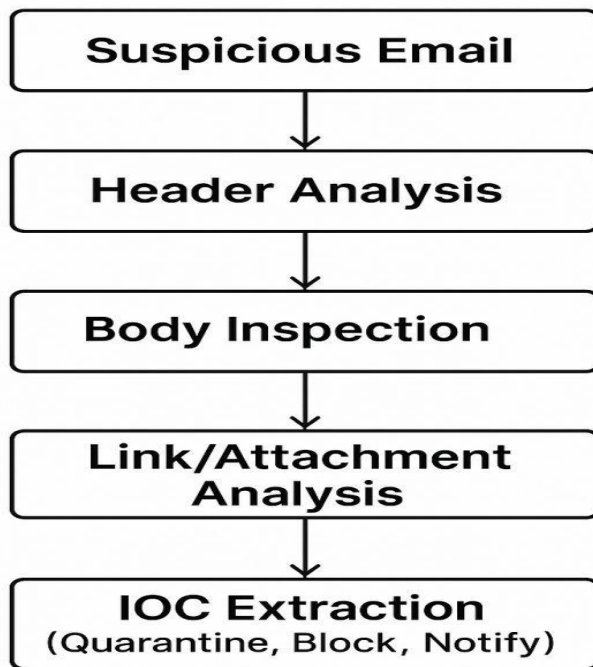


Verify / Decrypt Email

4. Advanced Spam and Phishing Detection



PHISHING EMAIL ANALYSIS



The company is experiencing increased phishing and spam despite basic filtering. The assessment asks for an improved detection model using **email headers and content analysis**.

A. Limitations of basic filtering

- Basic filtering may fail because:
- Attackers constantly change email content.
- New phishing messages may not match existing rules.
- Sender addresses can be spoofed.
- Keyword-based filtering can miss cleverly written spam.

- Genuine emails may sometimes be incorrectly blocked.

B. Header analysis

Important email-header checks include:

- **From:** Checks the apparent sender.
- **Reply-To:** Can reveal suspicious redirection.
- **Received:** Helps trace the sending path.
- **Return-Path:** Provides information about the return address.
- **SPF:** Checks whether the sending server is authorized.
- **DKIM:** Helps verify message integrity and domain authentication.

DMARC: Helps detect and handle domain spoofing.

C. Improved detection model

A combined **rule-based + machine-learning model** can be used.

Email

↓

Header + Content Analysis

↓

Feature Extraction

↓

Rules + ML Model

↓

Risk Score

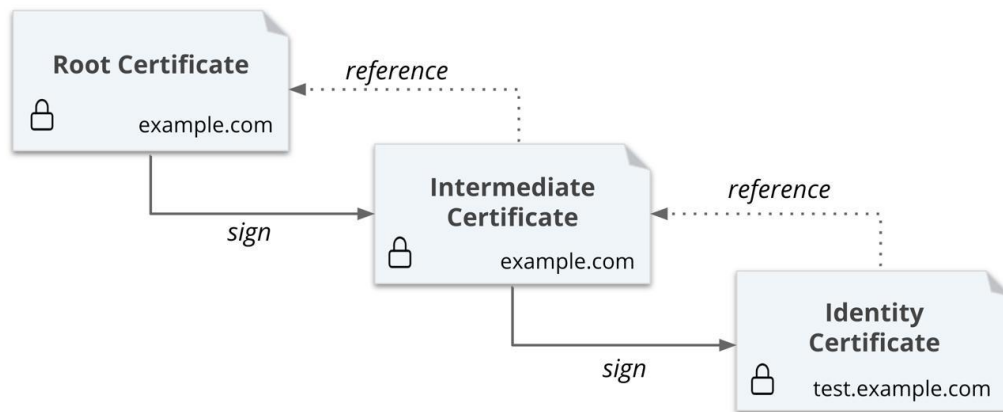
↓

Legitimate / Spam / Phishing

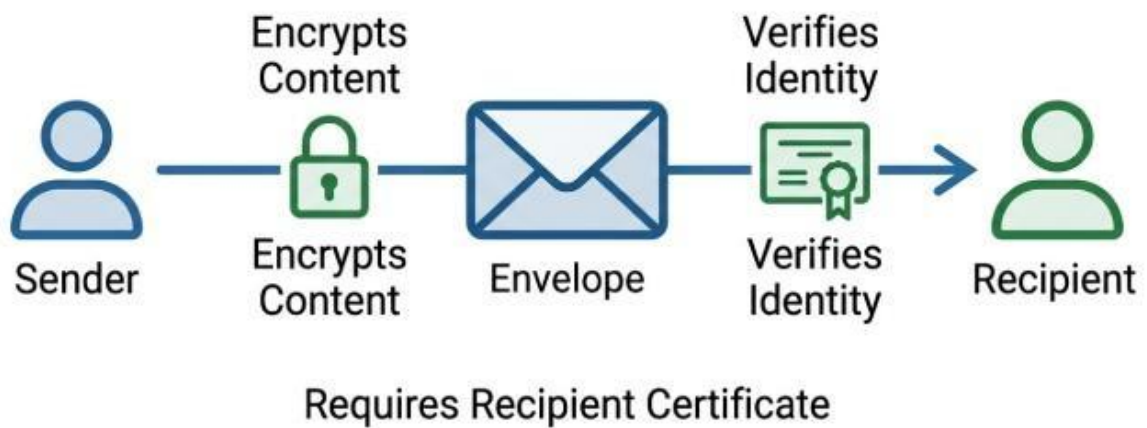
D. False-positive handling

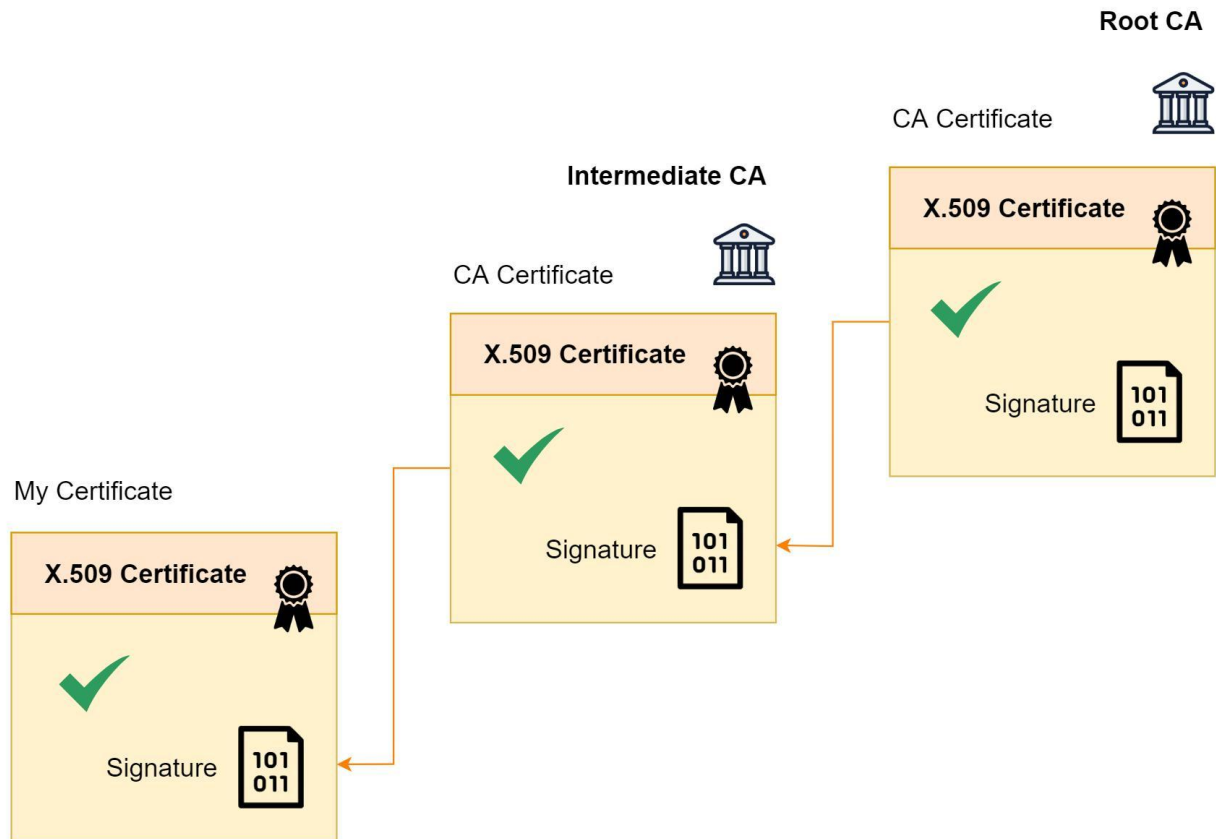
Suspicious messages can be moved to **quarantine** rather than immediately deleted. Administrators can review false positives and use them to improve future filtering.

5. S/MIME Certificate Management



How S/MIME Secures Email





The assessment identifies improper certificate handling as the security problem.

A. Possible vulnerabilities

- Expired certificates
- Invalid certificates
- Untrusted CA
- Incorrect certificate installation
- Exposed private keys
- Failure to check certificate revocation
- Weak certificate validation

B. Trust chain

A certificate can be validated through a chain such as:

User Certificate



Intermediate CA



Root CA

The system should check the certificate's **validity period, issuer, trust chain and revocation status**.

C. Secure certificate storage

Protect private keys with strong access controls.

Never share private keys.

Store keys securely.

Restrict access to certificates.

Renew certificates before expiration.

Revoke compromised certificates immediately.

D. User awareness

Users should be trained to:

Pay attention to certificate warnings.

Avoid accepting untrusted certificates.

Protect private keys.

Report suspicious certificate errors.

Conclusion

In conclusion, **IPSec, Security Associations, PGP, S/MIME, and advanced email filtering** play an important role in protecting modern communication systems. IPSec provides **integrity, authentication, and confidentiality** through AH and ESP, while IKE helps automate secure key and SA management.

For secure email, **PGP and S/MIME** provide encryption, authentication, and integrity, with S/MIME being particularly suitable for structured enterprise environments. Advanced header and content analysis can further strengthen protection against spam and phishing. Overall, proper configuration, automated key management, certificate validation, and continuous monitoring are essential for maintaining a **secure, reliable, and scalable network and email security system**.